

IT Security Summary

Last updated: October 2026.

1. Purpose

This summary answers the questions a pilot site's IT and security review most commonly asks, so that review does not become the institutional-approval bottleneck the Clinical Pilot Program is designed to remove. It states what is actually implemented today, plainly against what is not — consistent with the rest of this data room.

2. Hosting and Infrastructure

The application runs as a Docker container on Render (web service, Ohio region), with a managed Postgres 16 database (standard plan) for user, organization, and role data, and a separate scheduled job (Render cron service) for daily audit-log retention purging. Infrastructure is defined in `render.yaml` and built in CI against the same Dockerfile Render deploys.

3. Data Storage and Encryption at Rest

Data Room documents are encrypted at the application layer (Fernet/AES via the cryptography library) before they reach any storage backend, independent of what that backend does on its own. The storage backend itself is Cloudflare R2 (S3-compatible, persistent across redeloys) when configured; where it is not configured, the application falls back to local container disk, which does not survive a redeploy or a free-tier spin-down and is not intended for pilot or production use — R2 must be configured before a pilot site's documents are stored. Whether Render's managed Postgres enables storage-level encryption at rest by default has not yet been independently confirmed against Render's own documentation; this is an open item to close out before go-live, not an assumed yes.

4. Encryption in Transit

All HTTP traffic, including the application's WebSocket stream, is served over TLS, terminated by Render's managed routing layer.

5. Authentication and Access Control

Access is governed by role-based access control (RBAC) enforced server-side, with each application surface (main engine, clinician dashboard, payer portal, org admin) scoped to an explicit allowed-role set. Sessions are signed JSON Web Tokens (HS256 only — the decode path explicitly pins the algorithm, which is the documented mitigation for the one known python-jose CVE without an upstream fix), delivered via `httpOnly` cookies. Passwords are hashed with `bcrypt` via `passlib`, never stored in plain text.

6. Audit Logging

A persisted, Postgres-backed audit log (separate from the in-memory pipeline event feed used for the live dashboard) records user actions — signup, login success and failure, logout, and account approval, rejection, or disabling — and one row per completed or

failed agent-pipeline run, each with the acting identity, organization, IP address, and user agent where applicable. Default retention is 400 days, purged daily by a scheduled job.

Not yet implemented: record-level logging of individual PHI access events (who viewed which patient record, and when) — the same gap disclosed in Section 4 of the Business Associate Agreement.

7. Vulnerability and Dependency Management

Dependencies are scanned on every push and pull request via pip-audit in CI, with findings reported as build annotations; the step is currently warn-only rather than build-blocking, pending triage of the current finding set. Dependabot opens weekly update PRs for Python dependencies, the Docker base image, and the CI workflow's own GitHub Actions. Known, deliberately untreated findings (a starlette version pinned by the current FastAPI version; one unpatched python-jose CVE with a documented mitigation in place) are tracked with their rationale directly in requirements.txt.

8. Monitoring and Incident Response

Error tracking and alerting (Sentry) is built into the application and activates automatically once a project DSN is supplied; no DSN is configured in this environment today, so alerting is not yet live. CI's Docker build and import-smoke-test steps catch startup and dependency failures before a deploy reaches Render.

9. Subprocessors

Render (application hosting, managed Postgres, TLS termination) and, where configured, Cloudflare (R2 object storage for Data Room documents).

10. Known Gaps — Stated Together

For a reviewer who wants the complete list in one place rather than scattered across sections: no record-level PHI-access audit trail yet (Section 6); local-disk document storage is a non-persistent fallback only — R2 must be configured before any pilot site's documents are stored (Section 3); Render's default encryption-at-rest posture for its managed Postgres has not yet been independently confirmed (Section 3); Sentry alerting is not yet configured in this environment (Section 8); and a completed third-party security assessment or SOC 2 report does not yet exist — see the separate HIPAA, Security & SOC 2 Packet in the Document Room for readiness detail, which is not the same as a completed audit.

11. Contact

Questions about this summary: invest@cardioalive.com